

AGENT PASSPORT

Demo Alignment

Overview of Judge:

- 19 Judges (*two competition authorities (Kemei, Mayasari), a data-protection office (Birikujja), a national ID authority (Kisembo), a communications regulator (Tolessa), a capital markets authority (Ossiya), a partnerships/ecosystem strategist (Faisal), the BIS/architecture people (Carstens, Nolens), the AI-in-supervision leaders (Rusu, Black), plus the central-bank/payments clusters*).
- Payments is only 1/3 among all Judges
- Tilting product focus towards payment = Not Advised

Five Key Concern among all Judge/Hackathon

1. *Agents are a fraud surface we cannot see → signed, expiring passport, refuse the unverified, revocation propagates.*
2. *Who answers when it goes wrong → every passport resolves to an accountable legal person, audit trail.*
3. *Can a machine's decision be defended → AI only extracts, rules decide, human signs, replayable.*
4. *We lack budget/engineers → open source, rules as data.*
5. *Will it work with what we have → chains to existing identity rails, open schema.*

Alignment of Demo Vertical to the Five Concern: An accounting firm's agent filing tax returns, verified by an authority, refused when out of scope, with a human sign-off and a replayable audit trail, demonstrates every one of the five consensus concerns. (Our Demo Use Case)

Transferability is how we stand out

- The judging panel spans many problem spaces, competition, data protection, national ID, communications, capital markets, payments, and more.
- The goal is to make it look like infrastructure, not a sector solution: the next registry in the stack countries already run, one engine that serves different sectors by swapping the rules.
- **How we win:** build narrow, frame broad. We build one sector deeply and cleanly (HMRC self-assessment), end to end, then show in a single beat that the same engine works elsewhere by swapping the rule-pack. The build stays focused; the pitch reaches everyone.
- Our HMRC demo already answers the five concerns the whole panel shares.
 - Onboarding and verification shows who is accountable and that it is built on HMRC's real process.
 - The refusal (the agent tries to amend when only submission was granted, or file for an unauthorised client) shows we can stop the unverified.
 - Human sign-off plus a replayable audit trail shows the decision can be defended.
 - Revocation propagating (the authority revokes, the agent's next action fails) shows who answers when something goes wrong, a moment several judges specifically want to see.
- **Transferability:** swap the tax rule-pack for a non-tax context, same engine, which earns the competition, communications, and data-protection judges (a non-financial example lands even better than another financial one).
- **The bottom line:** the judging panel will likely reward a a cleanly-built single-sector demo that frames itself as transferable public infrastructure. That is exactly what we are building, so we do not need to add payments, we build HMRC properly and show, in one clean move, that the engine travels. (If time permits, explore transferability. Otherwise, Drop)

AGENT PASSPORT

(Fields for the Initial Skeleton - HMRC Self-Assessment demo)

The End-to-End journey:

Before the field lists, here is the whole flow in order, so every view has its place. Four parties, one clean path.

1. **Apply:** the accounting firm (Operator) submits its agent, its clients, and the authority it is requesting. (View 1)
2. **Review & issue:** HMRC (Authority) runs automated checks, a human officer approves, and a signed passport is issued defining the exact scope. (View 2)
3. **Act & check:** the agent tries an action; the relying party verifies the passport and the scope, then allows, denies, or escalates. (View 3)
4. **Maintain:** the authority can suspend or revoke a passport at any time; every action is logged and can be replayed. (see lifecycle section)

VIEW 1 = OPERATOR (the accounting firm applying to deploy its agent)

Relevance: What a tax officer would expect from a firm automating filing.

Firm identity

- Firm name
- Agent Services Account (ASA) reference ~ (designed for tax professionals)
- Agent Government Gateway ID ~ (to login to government portals)
- **Companies House number, if the firm is incorporated (lets the officer confirm the firm is a real registered entity)**

Accountable person

- Named responsible individual
- Role or title
- Professional body (ACCA, ICAEW, ATT, CIOT, or none)
- **Contact email / declaration that this person accepts responsibility for the agent's actions (this is who answers if something goes wrong = the accountability anchor)**

Compliance

- AML supervisory body (HMRC or a professional body)
- AML registration reference

Clients the agent will act for

- List of client UTRs (Unique Taxpayer References) ~ (Each individual in UK have a UTR and they use it as reference to file tax return)
- For each, whether the client has authorised the firm (64-8 / digital handshake): yes or no
 - 64-8 is the old paper/form way, a form the client signs authorising the firm to act for them.
 - Digital handshake is the modern online way, the client approves the firm through their own HMRC account.
- **Client consent to automated processing:** Confirmation the client is content for an AI agent (not only a human) to handle their filing. *This is a data-protection point (clients should know an automated system is involved.)

Requested authority (the scope being applied for)

- Task, for example "submit Self Assessment (SA100) returns"
- Tax year, for example 2025/26 ~ (In the UK, a standard personal tax year runs for 12 months, starting on 6 April and ending on 5 April the following year)

- **Action type:** submit only, or submit and amend
 - Submit only = the agent can file a return, but that is it. Once it is in, it cannot go back and change it.
 - Submit and amend = the agent can file a return and later go back and edit or correct one that's already been submitted.
- Optional guardrail/threshold to set: flag returns above a set value (i.e., involves a big enough amount) for human review
- **Requested validity period:** For instance, “for tax year 2025/26 only”. Makes the passport time-boxed by design, so authority is never open-ended.

The agent itself

- Agent name or ID
- Software name and version
- Agent public key (used for signing)
- **Proof the firm controls the matching private key:** The agent shall sign a challenge at application, so the authority knows the key is genuinely held by this agent, not just pasted in. (This is what makes ‘agent-bound’ real later.)
 - **Problem:** When the accounting firm registers its agent, it hands over the agent's public key. But a public key is, by design, public, anyone can copy it. **So there is a gap:** how does the authority know the firm actually controls the matching private key, rather than just having pasted in some public key (maybe one they copied from somewhere, or one they don't really own)?
 - **How the challenge fixes it:** the authority sends the agent a random one-off message and asks it to sign it. Because only the true private-key holder can produce a valid signature, checking that signature against the submitted public key proves the agent genuinely controls the key, rather than just pasting in a public key it does not own.
 - **Note:** Using a fresh random message each time also blocks anyone replaying an old captured signature.

VIEW 2(a) = REGULATOR (HMRC reviews and issues the passport)

Relevance: The officer reviews the application, then approves, requests more information, or rejects.

Review panel (what the officer sees to decide)

- All the operator fields above
- **Automated checks with status:** ASA validity, AML supervision confirmed, each client's 64-8 authorisation confirmed (anything unconfirmed is flagged) ~ (system does some quick check so human regulator do not need to review everything)
 - **ASA validity:** is the firm's Agent Services Account (its official "I'm a registered agent" account with HMRC) real and active? A fake or lapsed one gets flagged.
 - **AML supervision confirmed:** is the firm properly registered for anti-money-laundering supervision (with HMRC or a professional body)? Firms acting on tax matters are legally required to be. If it is missing, that is flagged.
 - **Each client's 64-8 authorisation confirmed:** for every client the agent wants to file for, has that client actually authorised this firm to act for them? Any client who has not given that permission gets flagged.
- Officer decision: approve, request more information, or reject
- Officer note or reason (required)

The issued passport

- Passport ID
- Issuing authority (HMRC)
- Agent ID, accountable firm, accountable person
- Granted scope, stated precisely: "submit SA100 returns, tax year 2025/26, submit only, for authorised clients"
- Issue date
- Expiry date (for example, end of the tax year, since agents re-authorise anyway)
- **Status:** active, suspended, or revoked
- Authority's digital signature
- **Not shown:** the client list, the accountable person's details, or any personal data. The passport carries the permission, not the personal data.

VIEW 2(b) = PASSPORT LIFECYCLE

Relevance: A real authority does not just issue and forget. This is what a tax officer would expect to be able to do after issuing, and it is where several of the strongest demo moments live.

- **Suspend:** temporarily freeze a passport (i.e. suspected compromise, ongoing review). The agent is refused until reinstated.
- **Revoke:** permanently cancel it (i.e. the firm loses AML supervision, a client withdraws authorisation, misuse detected). Takes effect on the agent's next action.
- **Renew / re-authorise:** issue a fresh passport for the next tax year; the old one expires. Keeps authority time-boxed.
- **Revocation status must be checkable in real time:** the relying party checks status at action time, so a revoked passport stops working immediately, not at some later sync.
- **Reason recorded:** every suspend/revoke carries an officer reason, for the audit trail.

VIEW 3 = RELYING PARTY (the system the agent submits to)

Relevance: Checks each action against the passport. Relying party means whoever the agent is trying to do something with, the system on the receiving end of the agent's action. In our HMRC example, it is HMRC's tax-filing system, the thing the agent submits the tax return to.

What the relying party sees on the passport

- Passport ID
- Issuing authority (HMRC)
- **Agent ID only:** Do not expose the accountable person's details here as the checker does not need them, and showing them leaks personal data. Keep accountability with the authority.
- Granted scope (task, tax year, action type)
- Issue date
- Expiry date (for example, end of the tax year, since agents re-authorise anyway)
- **Status:** active, suspended, or revoked
- Authority's digital signature
- **The agent's public key** (so the checker can confirm the agent signed this specific request)
- **Not shown:** the client list, the accountable person's details, or any personal data. The passport carries the permission, not the personal data.

Per-action check (when the agent acts)

- Action requested, for example "submit SA100 for client [reference], tax year 2025/26"
 - **The request is signed by the agent with its private key:** so the checker can prove it came from the genuine agent, not a stolen copy of the passport (proof-of-possession).
 - **Checks:** is the signature valid, is the passport still active, is the action within the granted scope, and is the client authorised
 - **Ordered check sequence:** (1) passport signature genuine? (2) passport active, not expired/revoked? (3) request genuinely signed by this agent? (4) action within scope? (5) client in the authorised set? Any 'no' stops it.
 - **Note on the client check:** the passport itself does not carry the full client list. When the agent acts, authorisation is confirmed against the authority's records by reference, so the passport stays a minimal credential (it carries the agent's permission, not everyone's personal data). Where the relying party is a separate organisation from the authority, this also means it can verify an action without ever seeing the underlying personal records.
- **Result:** ALLOW, DENY, or ESCALATE TO HUMAN
- Reason on deny or escalate, for example "amendment not permitted under scope" or "client not authorised"
- **Signed receipt returned for every result (allow and deny), so both the agent and the authority have tamper-evident proof of what was decided and why.**

REGULATORY, LEGAL & DATA PROTECTION CONSIDERATIONS

A regulatory judge will ask about these. (Relevant for 'regulatory fit' and 'guardrails' criterias)

- **Lawful basis & data minimisation (UK GDPR):** the passport is a minimal credential (it carries permission, not personal data.) Personal data stays with the authority. This is 'data protection by design', which UK GDPR expects.
- **Client transparency:** clients are told an AI agent may handle their filing (the consent field in View 1), so automated processing is not hidden from them.
- **Accountability stays human:** a named person is responsible; the AI only reads and extracts; fixed rules decide; a human officer signs off. No legally consequential decision is made by the model.
- **Auditability:** every issue, action, and revocation is logged with a signed receipt and can be replayed (supporting challenge, appeal, or investigation.)

- **Proportionate authorisation:** scope is narrow and time-boxed (one task, one tax year, submit-only unless amend is granted), so an agent can only ever do the specific thing it was approved for.
- **Existing-process alignment:** this mirrors HMRC's real agent authorisation (ASA, 64-8, UTR, SA100) rather than inventing a parallel regime (easier to adopt, easier to trust.)

NOTES (Across all three views)

- Every decision is written to an audit trail with a signed receipt, so any action can be traced and replayed.
- **In theory:** The full client list and personal data stay with the authority (**View 2**). The relying party (**View 3**) only checks a specific action, by reference. That separation is both the privacy safeguard and a genuine strength to show off.
- **The passport itself:** The passport carries only the agent's permission, not the taxpayers' personal data. So the checking mechanism verifies an action against the scope without the personal data needing to travel with the passport. In cases where the relying party is a different organisation from the authority, this separation genuinely protects personal data. They can verify the agent without ever seeing the underlying records.
- **Disclaimer - A note on this specific case:** In this demo example, the authority (HMRC) and the relying party (HMRC's filing system) are the same organisation, so HMRC naturally already holds the taxpayers' personal data, there is no separation to protect in this instance, because it is all HMRC's data to begin with. The privacy benefit becomes real in cases where the authority and the relying party are different organisations. For example, if a financial regulator issued the passport and a bank were the one checking the agent's action, the bank could verify what the agent is permitted to do without ever seeing the underlying personal records. The passport stays a minimal credential, it carries the agent's permission, not everyone's personal data, which is what makes the same model work cleanly whether the checker is the authority itself or a separate party.
- We must keep it clearly a modelled demo on synthetic data, not an implied HMRC integration (as no authority yet)
- Keep the authority (HMRC) as the trust anchor, and Legis Labs as merely the engine-builder (If we add payments and start sounding like a fintech, it will be suboptimal)